

Mestrado em Engenharia de Telecomunicações e Informática

Unidade Curricular: Segurança em Redes e Sistemas de Informação

Duarte Sá – Número: 122609

Tiago Nobre – Número: 122632

Martim Teixeira – Número: 122636

Henrique Lopes – Número: 122634

João Matos – Número: 122639

19/10/2026

Autenticação Simples vs. Autenticação Multifator: Segurança baseada no risco e no perfil do utilizador

Docentes: Valderi Reis Quietinho Leithardt

Maurício Machado da Rosa

Resumo

Este trabalho tem como objetivo analisar as diferenças entre a Autenticação de Fator Único (SFA) e a Autenticação Multifator (MFA), considerando as suas características, vantagens, limitações e adequação a diferentes contextos de utilização. São comparados diferentes métodos e tecnologias de autenticação, tendo em conta a segurança, a facilidade de utilização e os riscos associados a cada solução. É também analisada a necessidade de implementar MFA de acordo com o perfil do utilizador, a sensibilidade da informação protegida e o nível de risco.

O trabalho encontra-se disponível no GitHub, onde podem ser consultados os respetivos ficheiros e materiais: `https://github.com/LETI-122609/SFA-Vs-MFA.git`.

Palavras-chave: Autenticação; SFA; MFA; segurança; perfil; utilizador.

Índice

1 Glossário **4**

2 Introdução **5**

3 Tipos de Autenticação **6**

4 Autenticação Simples e Autenticação Multifator **6**
4.1 Autenticação Simples (SFA) 6
4.2 Autenticação Multifator (MFA) 7

5 Comparação entre SFA e MFA **9**
5.1 Segurança 9
5.2 Facilidade de utilização 9
5.3 Implementação 10
5.4 Impacto na experiência do utilizador 10

6 Utilidade e necessidade da MFA **11**
6.1 Fragilidade da autenticação por um único fator 11
6.2 Eficácia da MFA 11
6.3 Limitações da MFA 11
6.4 Escolha do método de MFA 12

7 Diferentes perfis de utilizadores **12**
7.1 Utilizador comum 12
7.2 Utilizador idoso 13
7.3 Utilizador com acesso a informação sensível 14
7.4 Administrador de sistemas 15

8 Exemplos práticos e tecnologias **17**
8.1 TOTP (Time-Based One-Time Password) 17
8.2 FIDO2 & WebAuthn 18
8.3 Autenticação através de aplicações móveis e notificações push 19
8.4 Códigos de utilização única por SMS 20
8.5 Smart Cards 21
8.6 Autenticação biométrica 22
8.7 Comparação entre as tecnologias analisadas 23

9 Conclusões **24**
9.1 Trabalhos Futuros 24

10 Referências **25**

1 Glossário

SFA Single-Factor Authentication – Autenticação de um único fator.

Phishing – técnica de engenharia social através da qual um atacante procura enganar um utilizador para obter informações confidenciais.

MFA Multi-Factor Authentication – Autenticação Multifator.

Number matching – Mecanismo de MFA em que o utilizador tem de introduzir, na aplicação de autenticação, um número apresentado no ecrã de início de sessão.

VPN Virtual Private Network – Rede privada virtual: tecnologia que permite estabelecer uma ligação protegida a uma rede através de outra rede, como a Internet.

Ransomware – Tipo de software malicioso que bloqueia o acesso a sistemas ou dados, frequentemente através de encriptação, e exige um resgate para a sua recuperação.

Token RSA – Dispositivo ou mecanismo de autenticação associado à tecnologia RSA SecurID, utilizado para gerar códigos temporários que reforçam a verificação da identidade.

Sistemas de controlo industrial ICS – Sistemas utilizados para monitorizar e controlar processos industriais, incluindo equipamentos e operações físicas.

Smart Cards – Cartões Inteligentes

NIST – National Institute of Standards and Technology

Cartões PIV – Smarts cards para a identificação de uma pessoa

2 Introdução

Este trabalho tem como objetivo analisar as diferenças entre a Autenticação Simples (Single-Factor Authentication – SFA) e a Autenticação Multifator (Multi-Factor Authentication – MFA), avaliando as suas características, vantagens, limitações e adequação a diferentes contextos de utilização.

Pretende-se compreender em que situações a implementação de MFA é necessária ou recomendada, considerando o nível de risco, a sensibilidade da informação protegida e o perfil dos utilizadores. O trabalho procura também analisar o equilíbrio entre segurança, facilidade de utilização e acessibilidade.

Por fim, serão estudadas algumas das principais tecnologias de autenticação, analisando as duas características e o modo como podem ser utilizadas na implementação de mecanismos de MFA.

O relatório encontra-se organizado em várias secções. Inicialmente, são apresentados os principais tipos de autenticação e os conceitos de SFA e MFA. A seguir, são comparadas ambas as abordagens e analisada a necessidade de recorrer a MFA em função do risco e do perfil dos utilizadores. Por fim, são exploradas diferentes tecnologias de autenticação e apresentados cenários que permitem avaliar a adequação das soluções estudadas a diferentes contextos.

3 Tipos de Autenticação

Nesta secção serão exploradas as diferentes categorias de fatores de autenticação, nomeadamente, algo que se sabe (PINs, passwords, etc.), algo que se é (Biometria) e algo que se possui (token fisico, cartão, etc.).

O exemplo mais comum de autenticação é a autenticação através de password, onde o utlizador autentica-se através da criação de um nome de utilizador e de uma password, e acede ao site/aplicação pretendida. Outro tipo de autenticação é a autenticação PIN, onde o utilizador, através de uma combinação de valores numéricos autentica-se e acede ao conteúdo pretendido. A segurança destes exemplos depende dos requisistos requeridos pelo sistema de criação de utilizadores presente na aplicação. Boas práticas da criação de passwords/PINs, segundo o site "TechTarget - *Single-factor authentication*"incluem a criação de um(a) PIN/password complexo/a e robusto/a de forma a que ninguém, através de ataques de força bruta, consiga descobri-la.

Outro exemplo de um tipo de autenticação são os dados biometricos. Isto corresponde a características físicas, biológicas ou comportamentais únicas de um indivíduo que podem ser medidas e usadas para identificação, pois são considerados são únicos e exclusivos a cada indivíduo. Com isto, a autenticação através de dados biométricos corresponde a uma ferramenta valiosa para autenticação e segurança, apesar de não serem completamente invulneráveis a ameaças.

Por fim, um outro tipo de autenticação corresponde à utilização de um token físico, ou token de hardware, que corresponde a um componente de hardware que autentica um utilizador. Os tokens físicos podem assumir várias formas, incluindo pequenos tokens USB, cartões inteligentes ou dispositivos dedicados que geram senhas. Os tokens físicos geralmente funcionam junto com outros métodos de autenticação, como um nome de usuário e uma senha, mas alguns sistemas podem usá-los como o único método de autenticação necessário.

4 Autenticação Simples e Autenticação Multifator

4.1 Autenticação Simples (SFA)

A SFA, segundo a NIST, é defenida como uma caractristica de um sistema de autenticação ou de autenticador, onde é apenas exigido um fator de autenticação para verificar a identidade de um utilizador e conceder-lhe acesso a um determinado sistema ou recurso.

Devido à sua simplicidade, facilidade de utilização e baixo custo de implementação, a SFA é frequentemente adotada em diferentes sistemas e aplicações. Entre os vários

métodos existentes, o mais comum é a autenticação baseada num nome de utilizador e numa password ou PIN.

Apesar da sua simplicidade, a segurança da SFA depende, em grande medida, do tipo de fator utilizado e da forma como este é protegido. No caso das palavras-passe e dos PINs, a utilização de credenciais fracas ou previsíveis pode facilitar o acesso não autorizado. Entre as ameaças associadas a estes métodos encontram-se os ataques de dicionário, os ataques de força bruta, o roubo de credenciais e as técnicas de engenharia social, como o *phishing*.

Para reduzir os riscos associados à SFA, podem ser implementadas diversas medidas de segurança, tais como a definição de políticas de palavras-passe robustas, a limitação do número de tentativas de autenticação falhadas, o armazenamento seguro das credenciais e a sensibilização dos utilizadores para prevenir ataques de *phishing*. Estas medidas contribuem para dificultar o acesso não autorizado, embora não eliminem completamente as vulnerabilidades associadas à utilização de um único fator de autenticação.

Entre as principais desvantagens da SFA, destacam-se as seguintes:

- **Reutilização de credenciais:** a utilização da mesma palavra-passe em várias contas aumenta o risco de comprometimento de múltiplos serviços caso essa palavra-passe seja descoberta ou exposta.
- **Gestão de credenciais:** quando os utilizadores possuem várias contas com palavras-passe diferentes, torna-se mais difícil memorizar e gerir todas as credenciais de forma segura.
- **Comprometimento sem conhecimento do utilizador:** as credenciais podem ser roubadas ou utilizadas indevidamente sem que o utilizador se aperceba, permitindo o acesso não autorizado às suas contas e aos recursos associados.

Apesar destas limitações, a SFA pode ser adequada em determinados contextos, dependendo do risco associado ao sistema, da sensibilidade da informação protegida e das medidas de segurança complementares existentes. Contudo, quando é necessário reforçar a proteção contra acessos não autorizados, sobretudo em sistemas que armazenam informação sensível ou permitem operações críticas, pode justificar-se a utilização da MFA.

4.2 Autenticação Multifator (MFA)

A MFA, como o nome indica, exige a combinação de mais do que um fator de autenticação diferente, de forma a que o comprometimento de um fator não seja suficiente para permitir o acesso ao sistema. Como parte de uma lógica de defesa em profundidade, reduz significativamente o sucesso de ataques, partindo do pressuposto que o grau de

dificuldade aumenta bastante com a necessidade de comprometer os demais fatores. Esta surgiu como solução para aumentar a robustez do processo de autenticação.

Um ponto fulcral para este tipo de autenticação é a exigênca de que os fatores sejam de categorias distintas. Uma palavra-passe e um PIN, por exemplo, pertencem ambos à mesma categoria, ou seja, podem ser obtidos pelos mesmos meios, como phishing, engenharia social ou fuga de dados, pelo que quem consegue um, consegue frequentemente o outro. Em contrapartida, combinar uma palavra-passe (algo que se sabe) com um código aleatório temporário gerado num telemóvel (algo que apenas o dono tem), ou com uma característica biométrica (inerência), obriga a um segundo tipo de ataque, como o roubo físico do dispositivo ou a falsificação do elemento biométrico, que é distinto e consideravelmente mais difícil de executar à distância. É esta independência entre fatores que reduz a probabilidade de um único incidente comprometer todo o processo de autenticação e que justifica a distinção entre MFA e a simples acumulação de passos do mesmo tipo.

Apesar de aumentar de forma significativa a proteção, a MFA não é imune a ataques, e a sua eficácia depende da forma como é implementado. Para maximizar os seus benefícios e de forma a se obter os resultados pretendidos, devem ser adotadas medidas como a escolha de métodos mais resistentes ao phishing, em detrimento de métodos mais frágeis, a disponibilização de mecanismos de recuperação de conta seguros, a limitação do número de pedidos de confirmação enviados ao utilizador e a sensibilização dos utilizadores para não aprovarem pedidos que não iniciaram.

Entre as principais desvantagens da MFA, destacam-se as seguintes:

- **Fricção na experiência do utilizador:** a exigência de uma etapa adicional torna o acesso mais demorado e pode reduzir a aceitação do sistema.
- **Dependência de dispositivos ou elementos físicos:** a perda, o roubo, a avaria ou a falta de acesso ao dispositivo (telemóvel, token, chave) podem impedir um utilizador legítimo de aceder à sua conta.
- **Dependência de um único fator:** uma vez comprometido o único fator de autenticação, um atacante poderá conseguir aceder ao sistema sem necessitar de ultrapassar uma segunda etapa de verificação.
- **Recuperação de conta:** os mecanismos de recuperação, necessários para quem perde o segundo fator, podem tornar-se o elo mais fraco do sistema se forem mal desenhados.
- **Proteção desigual consoante o método:** alguns métodos oferecem menos proteção do que outros.

Apesar de reforçar a segurança, a MFA nem sempre é a solução mais proporcionada. A sua utilização justifica-se sobretudo em sistemas que protegem informação sensível ou permitem operações críticas, enquanto em contextos de menor risco a fricção adicional pode superar o benefício obtido. Abordagens como a autenticação baseada no risco procuram precisamente conciliar os dois objetivos, exigindo verificações adicionais apenas quando o contexto o justifica, e há indícios de que podem ser mais usáveis do que as variantes de MFA, com segurança percebida comparável.

5 Comparação entre SFA e MFA

Nesta secção irão ser comparadas as duas abordagens tendo em consideração aspetos como segurança, facilidade de utilização, implementação e impacto na experiência do utilizador.

5.1 Segurança

Do ponto de vista da segurança, a SFA apresenta algumas limitações, sobretudo quando se baseia exclusivamente em palavras-passe. A utilização de palavras-passe fracas, reutilizadas em diferentes serviços ou comprometidas através de ataques de *phishing* pode permitir que terceiros acedam a uma conta sem autorização. Assim, a segurança deste método depende significativamente da robustez das credenciais e da capacidade do utilizador para as proteger.

Por outro lado, a MFA reforça a proteção das contas ao exigir fatores adicionais de autenticação, como um dispositivo na posse do utilizador, um código temporário ou uma característica biométrica. Desta forma, mesmo que uma palavra-passe seja comprometida, um atacante poderá não conseguir aceder à conta sem ultrapassar os mecanismos adicionais de verificação. Contudo, a MFA não elimina todos os riscos, uma vez que determinadas implementações continuam vulneráveis a ataques de *phishing*, interceção de códigos e técnicas de engenharia social. A eficácia deste método depende, por isso, dos fatores utilizados e da forma como são implementados. Em termos gerais, a MFA oferece um nível de proteção superior ao da SFA baseada exclusivamente em palavras-passe.

5.2 Facilidade de utilização

A SFA permite um início de sessão geralmente mais simples e rápido, enquanto a MFA acrescenta passos ao processo de autenticação devido à verificação de dois ou mais fatores de categorias diferentes.

Segundo Weir et al. (2010), num estudo entre MFA e SFA, os métodos de autenticação de dois fatores obtiveram resultados superiores nas métricas de usabilidade avaliadas

em serviços bancários online. No entanto, os utilizadores mais experientes preferiram o método de fator único que utilizavam habitualmente, considerando-o mais seguro e conveniente.

Assim, a SFA privilegia a simplicidade de acesso, enquanto a MFA reforça a segurança. A facilidade de utilização de ambos os métodos depende da solução implementada, da familiaridade dos utilizadores e do contexto de utilização.

5.3 Implementação

A implementação da SFA tende a ser mais simples, uma vez que requer apenas um mecanismo de autenticação. No caso mais comum, baseado em palavras-passe, a infraestrutura necessária pode limitar-se à gestão de credenciais e aos respetivos mecanismos de validação.

Em contrapartida, a MFA exige uma infraestrutura mais complexa, capaz de integrar e validar diferentes mecanismos de autenticação. Dependendo da solução escolhida, poderá ser necessário implementar aplicações móveis, serviços de envio de códigos, dispositivos de segurança ou sistemas de verificação biométrica. Existem também custos associados à manutenção, ao suporte técnico e à recuperação de contas quando os utilizadores perdem o acesso ao segundo fator.

Apesar destes encargos adicionais, o investimento na MFA pode justificar-se em contextos empresariais, serviços bancários e sistemas que processam informação confidencial, nos quais as consequências de um acesso não autorizado podem ser particularmente graves. Assim, a escolha entre as duas abordagens deve considerar não apenas os custos de implementação, mas também os riscos de segurança e os requisitos específicos do sistema.

5.4 Impacto na experiência do utilizador

Relativamente à experiência do utilizador, a MFA pode tornar o processo de autenticação mais demorado e frustrante relativamente à SFA, sobretudo para utilizadores menos experientes, devido aos passos adicionais e à necessidade de alternar entre dispositivos para introduzir códigos de verificação. Segundo Allafi e Darem (2025), a MFA apresentou uma taxa de erro de 14% e uma satisfação média de 3,0 em 5. Em contrapartida, a autenticação biométrica obteve uma satisfação de 4,5 em 5 e uma taxa de erro de 2,5%, destacando-se pela rapidez e facilidade de utilização.

Deste modo, conclui-se que a experiência do utilizador depende não apenas do número de fatores de autenticação, mas também da facilidade com que estes podem ser utilizados no contexto habitual de acesso. A seleção de mecanismos intuitivos e fiáveis permite conciliar a segurança com a conveniência.

6 Utilidade e necessidade da MFA

6.1 Fragilidade da autenticação por um único fator

A necessidade de recorrência à MFA deve-se, na grande maioria dos casos, à fragilidade das credenciais baseadas num único fator. As palavras-passe podem ser adivinhadas, expostas em fugas de dados ou obtidas através de técnicas de engenharia social, como por exemplo o *phishing*. Em casos onde isto acontece, um atacante com a credencial correta consegue aceder à conta sem qualquer obstáculo adicional. A MFA procura eliminar esta dependência, exigindo que o atacante comprometa também um segundo fator de uma categoria distinta, o que aumenta significativamente a dificuldade e o custo do ataque.

6.2 Eficácia da MFA

A eficácia da MFA não é apenas intuitiva, sendo também comprovada por dados empíricos. Segundo o estudo de Meyer et al. (2023), que analisou um vasto conjunto de contas do Azure Active Directory com atividade suspeita, a MFA reduz o risco de comprometimento em 99,22% na população total e em 98,56% nos casos em que as credenciais tinham sido divulgadas. Este último valor é particularmente relevante, uma vez que mostra que, mesmo quando a palavra-passe já é conhecida pelo atacante, a MFA continua a impedir a maioria dos acessos indevidos. O mesmo estudo demonstrou ainda que aplicações de autenticação dedicadas, como o Microsoft Authenticator, oferecem mais proteção do que o SMS, embora ambos os métodos sejam muito superiores à ausência de MFA.

Um estudo da Google, apresentado por Thomas e Moscicki (2019), chegou a conclusões na mesma linha ao analisar o efeito de associar um número de telefone de recuperação a uma conta. Mesmo uma forma tão elementar de MFA como a associação de um número de telemóvel a uma conta mostrou-se capaz de bloquear até 100% dos *bots* automáticos, 99% dos ataques de *phishing* em massa e 66% dos ataques direcionados.

6.3 Limitações da MFA

No entanto, a MFA não é uma forma de proteção absoluta, e a sua eficácia varia consoante o método escolhido. Entre os ataques capazes de contornar certas formas de MFA encontram-se o *phishing* em tempo real, nomeadamente através de ataques MITM (*Man-in-the-Middle*), e o *push bombing*, também conhecido como *MFA fatigue*. Nos ataques MITM, o atacante coloca-se entre o utilizador e o serviço legítimo, através de um *site* falso que funciona como intermediário, intercetando em tempo real a palavra-passe, o código de MFA e o *token* de sessão resultante. No *push bombing*, segundo a CISA (2022a), o atacante bombardeia o utilizador com notificações de aprovação até que este aceite por

engano ou por cansaço.

Por este motivo, a CISA (2022a) recomenda que as organizações que utilizam MFA baseada em aplicação, SMS ou chamada de voz migrem para MFA resistente a *phishing* sempre que for possível, sendo que a única autenticação resistente a *phishing* amplamente disponível é a baseada em FIDO/WebAuthn. Quando essa migração não é viável, a CISA (2022b) sugere, como solução intermédia, a utilização de *number matching* nas notificações *push*.

6.4 Escolha do método de MFA

Assim, a MFA é hoje considerada uma medida essencial de segurança, sobretudo em contas de correio eletrónico, serviços financeiros e sistemas que armazenam informação sensível ou permitem operações críticas. Apesar de nem todos os métodos oferecerem o mesmo nível de proteção, qualquer forma de MFA representa um reforço face à autenticação por um único fator. A decisão sobre o tipo de MFA a adotar deve ter em conta o nível de risco do recurso protegido, o perfil do utilizador e o equilíbrio entre segurança e experiência de utilização. Em geral, quanto maior a sensibilidade da informação ou os privilégios da conta, mais robusto deve ser o método de autenticação utilizado.

7 Diferentes perfis de utilizadores

7.1 Utilizador comum

Nesta secção, iremos analisar um caso ilustrativo que permite compreender os riscos associados à utilização de mecanismos de autenticação por parte de um utilizador comum, bem como a importância da implementação do MFA.

Através deste testemunho, presente em "CISA - *Turn on Multifactor Authentication (MFA)*"percebemos a importância da utilização do MFA, uma vez, que neste caso, o Deandre subestimou os riscos de um ataque informático por considerar que não tinha presença nas redes sociais para ser um alvo. No entanto, este exemplo demonstra que qualquer utilizador pode ser vítima de um ataque, independentemente da sua popularidade ou quantidade de informação que partilha.

Para além disto, o acesso indevido a uma conta de e-mail teve consequências, permitindo aos atacantes aceder a serviços associados como contas bancárias e aplicações de compras. Este cenário demonstra a importância de proteger as contas que funcionam como ponto de recuperação ou acesso a serviços, uma vez que o seu comprometimento pode levar a perdas financeiras ou exposição de infrmação pessoal.

Neste contexto, embora a SFA possa ser suficiente para algumas contas de baixo

risco, a sua utilização isolada apresenta limitações. Caso a palavra-passe seja descoberta, roubada ou obtida através de uma mensagem de phishing, um atacante poderá conseguir aceder à conta sem necessitar de ultrapassar uma segunda barreira de autenticação.

Por outro lado, embora a MFA não elimine completamente o risco de ataque, reduz significativamente a probabilidade de acesso não autorizado, sobretudo quando são utilizados métodos resistentes a phishing. Desta forma, como a autenticação multifator adiciona uma (ou mais) camada de segurança, mesmo que a password seja comprometida, o atacante poderá não conseguir ter acesso à conta.

Assim, para um utilizador comum, a utilização de um MFA é bastante recomendada principalmente em contas de email, redes sociais (Facebook, Instagram, Whatsapp, etc.), aplicações bancárias bem como noutros serviços que armazenem informações pessoais ou permitam recuperar o acesso a outras contas. Para além disso, a escolha dos mecanismos de autenticação deve ter em consideração não só a facilidade de utilização, mas também as possíveis consequências de um eventual comprometimento. Deste modo, a MFA constitui uma medida de segurança importante para o quotidiano digital, permitindo reforçar a proteção das contas sem eliminar o equilíbrio entre segurança e comodidade.

7.2 Utilizador idoso

A utilização da autenticação MFA, apesar de proporcionar uma proteção adicional às contas online, nem sempre é adotada por todos os utilizadores, podendo existir dificuldades particulares na sua utilização por parte de algumas pessoas idosas. Esta situação pode estar relacionada com a dificuldade de utilização e a acessibilidade dos mecanismos de autenticação disponíveis, bem como com a sua compatibilidade com os dispositivos utilizados.

Neste contexto, Das et al. (2019), no estudo Why Don't Elders Adopt Two-Factor Authentication? Because They Are Excluded by Design", analisaram a experiência de pessoas com mais de 60 anos na utilização de mecanismos de autenticação de dois fatores, dando particular atenção às chaves de segurança físicas com ligação USB. Através de entrevistas e da observação dos participantes, os autores identificaram obstáculos à adoção destes dispositivos, nomeadamente as suas dimensões reduzidas, facilitando a sua perda, e sua dependência de determinados dispositivos e navegadores para o seu funcionamento. Estes resultados evidenciam que as dificuldades na utilização da MFA podem estar relacionadas não só com os utilizadores, mas também com a conceção e a acessibilidade das próprias soluções tecnológicas.

Além disso, outros métodos de autenticação, como os códigos PIN, as passwords e a biometria, podem apresentar desafios específicos para alguns utilizadores idosos. Por exemplo, a utilização de palavras-passe complexas pode dificultar a memorização, en-

quanto determinados métodos biométricos ou processos de autenticação podem apresentar dificuldades de utilização, dependendo das capacidades e da familiaridade de cada pessoa com a tecnologia. No entanto, estas dificuldades não se verificam necessariamente em todas as pessoas idosas, uma vez que as suas competências digitais e necessidades variam de indivíduo para indivíduo.

Assim, a adoção da MFA por este grupo de utilizadores deve ter em consideração tanto o nível de segurança necessário como a facilidade de utilização dos mecanismos disponíveis. Em aplicações que envolvam informação sensível, como serviços bancários ou contas que permitam o acesso a dados pessoais, a autenticação multifator é necessária para reduzir o risco de acesso não autorizado. Deste modo, em vez de se evitar a MFA devido a possíveis dificuldades de utilização, deve procurar-se selecionar métodos acessíveis e adequados às necessidades de cada utilizador, garantindo um equilíbrio entre segurança e usabilidade.

7.3 Utilizador com acesso a informação sensível

Em maio de 2021, a Colonial Pipeline, uma empresa responsável pelo transporte de combustíveis nos Estados Unidos, foi alvo de um ataque de *ransomware* que afetou os seus sistemas informáticos e levou à interrupção temporária das operações do seu sistema de transporte. Este incidente demonstrou os riscos associados à proteção insuficiente das contas que permitem o acesso a sistemas de uma organização responsável por uma infraestrutura crítica.

Durante uma audição perante o Senado dos Estados Unidos, realizada a 8 de junho de 2021, Joseph Blount, presidente executivo da Colonial Pipeline, foi questionado sobre as medidas de autenticação utilizadas pela empresa antes do ataque. Na sua declaração, confirmou que uma conta associada a uma VPN antiga, que se acreditava já não estar destinada a ser utilizada, estava protegida apenas por autenticação de fator único. Embora a palavra-passe fosse complexa, não existia um segundo fator de autenticação que dificultasse o acesso por parte de terceiros que obtivessem as credenciais.

Segundo U.S. Senate Committee on Homeland Security and Governmental Affairs - Portman Presses President and CEO of Colonial Pipeline on Gaps in Cybersecurity Practices, o que aconteceu foi o seguinte:

"O senador Rob Portman salientou que a utilização de autenticação multifator constitui uma medida básica de segurança, uma vez que torna mais difícil o acesso não autorizado mesmo quando uma palavra-passe é comprometida. Quando questionado sobre a utilização de MFA na conta em causa, Joseph Blount confirmou a ausência deste mecanismo e explicou que, nas operações habituais da empresa, eram utilizados tokens RSA para reforçar a autenticação dos acessos remotos. No final desta parte da audição,

concordou expressamente que a utilização de autenticação multifator deveria ser recomendada.

Segundo o testemunho escrito de Joseph Blount, a empresa suspeitava que os atacantes tinham explorado o perfil de uma VPN antiga que não deveria estar em utilização. Contudo, na altura, a investigação ainda procurava determinar de que forma as credenciais necessárias tinham sido obtidas. Assim, embora tenha sido confirmada a existência de uma conta sem MFA, não ficou demonstrado que a ausência deste mecanismo tenha sido a única causa do incidente."

Este caso evidencia um problema particularmente relevante quando os utilizadores possuem acesso a sistemas ou informação sensível: uma conta com permissões de acesso pode constituir um ponto de entrada para um atacante que consiga obter as respetivas credenciais. Quando essa conta está protegida exclusivamente por uma palavra-passe, o seu comprometimento pode permitir o acesso sem que seja necessária uma segunda verificação da identidade. Além disso, a existência de contas antigas que continuam acessíveis, mesmo quando já não são necessárias, aumenta a superfície de ataque da organização.

No contexto de uma infraestrutura crítica, as consequências de um incidente informático podem ultrapassar a exposição de informação confidencial, afetando também a continuidade dos serviços e as operações da organização. No caso da Colonial Pipeline, a empresa interrompeu temporariamente as operações do sistema de transporte para conter o incidente e reduzir o risco de propagação do ataque aos sistemas de controlo industrial. Esta decisão demonstra a importância de proteger não só os dados, mas também os sistemas e recursos cuja disponibilidade é essencial para o funcionamento de uma organização.

Desta forma, os utilizadores com acesso a informação sensível, sistemas críticos ou recursos administrativos devem dispor de mecanismos de autenticação adequados ao nível de risco das suas funções. A implementação de MFA, a desativação de contas e acessos obsoletos, a revisão periódica das permissões e a monitorização dos acessos são medidas importantes para reduzir a probabilidade de comprometimento. Este exemplo demonstra que a segurança da autenticação deve ser definida tendo em conta não apenas a identidade do utilizador, mas também os recursos a que este pode aceder e as consequências de uma utilização indevida da sua conta.

7.4 Administrador de sistemas

Os utilizadores com privilégios elevados, como administradores de sistemas, constituem alvos particularmente atrativos para atacantes. O comprometimento das suas contas pode conceder acesso profundo, persistente e muitas vezes discreto a infraestruturas críti-

cas, incluindo sistemas de produção, bases de dados e mecanismos de gestão de identidade. Por essa razão, as necessidades de autenticação destes utilizadores são substancialmente mais exigentes do que as de um utilizador comum.

Um caso particularmente ilustrativo é o incidente que afetou a Cloudflare em outubro de 2023, é explicado no documento "How Cloudflare mitigated yet another Okta compromisse":

"A 18 de outubro de 2023, a Cloudflare detetou ataques ao seu sistema que conseguiu rastrear até à Okta. Os atores maliciosos aproveitaram um token de autenticação comprometido na Okta para aceder à instância Okta da Cloudflare, utilizando uma sessão aberta com privilégios administrativos. A deteção em tempo real e a resposta pronta da Equipa de Resposta a Incidentes de Segurança (SIRT) da Cloudflare permitiram conter o incidente e minimizar o impacto nos sistemas e dados da empresa. Nenhuma informação ou sistema de clientes foi afetado.

Esta foi a segunda vez que a Cloudflare foi afetada por uma violação dos sistemas da Okta. Em março de 2022, num incidente anterior, a Cloudflare concluiu que o atacante não teve acesso a nenhum dos seus sistemas ou dados, uma vez que a utilização de chaves de hardware para autenticação multifator (MFA) impediu o ataque.

No incidente de 2023, o atacante acedeu ao sistema de suporte ao cliente da Okta e visualizou ficheiros carregados por determinados clientes em casos de suporte recentes. No caso da Cloudflare, o atacante conseguiu sequestrar um token de sessão de um ticket de suporte criado por um funcionário da Cloudflare, comprometendo duas contas separadas de funcionários na plataforma Okta. A Cloudflare detetou esta atividade internamente mais de 24 horas antes de ter sido notificada pela Okta, tendo contactado a Okta sobre a violação antes de ser informada por esta."

A comparação entre os dois incidentes é particularmente relevante: em 2022, a MFA baseado em chaves de hardware funcionou como barreira no momento da autenticação e impediu o acesso; em 2023, o ataque não explorou o processo de login, mas sim a reutilização de uma sessão já autenticada, um vetor que contorna a MFA tradicional. Este caso demonstra que a proteção de contas com privilégios elevados exige não só MFA resistente a phishing, mas também gestão rigorosa do ciclo de vida das sessões e monitorização contínua. A Cloudflare recomenda, por isso, a ativação de MFA baseado em hardware para todas as contas de utilizador, afirmando que "apenas passwords não oferecem o nível de proteção necessário contra ataques".

8 Exemplos práticos e tecnologias

Nesta secção serão apresentadas e analisadas diferentes tecnologias e métodos de MFA, considerando as suas principais características, o seu funcionamento, as vantagens e limitações e o contributo para a segurança dos processos de autenticação. Serão abordadas soluções baseadas em códigos temporários, chaves de segurança físicas, aplicações móveis, cartões inteligentes e autenticação biométrica, permitindo comparar os diferentes mecanismos e compreender a sua adequação a diferentes perfis de utilizadores e níveis de risco.

8.1 TOTP (Time-Based One-Time Password)

A tecnologia **TOTP** gera um código numérico temporário que age como uma segunda verificação da identidade do utilizador.

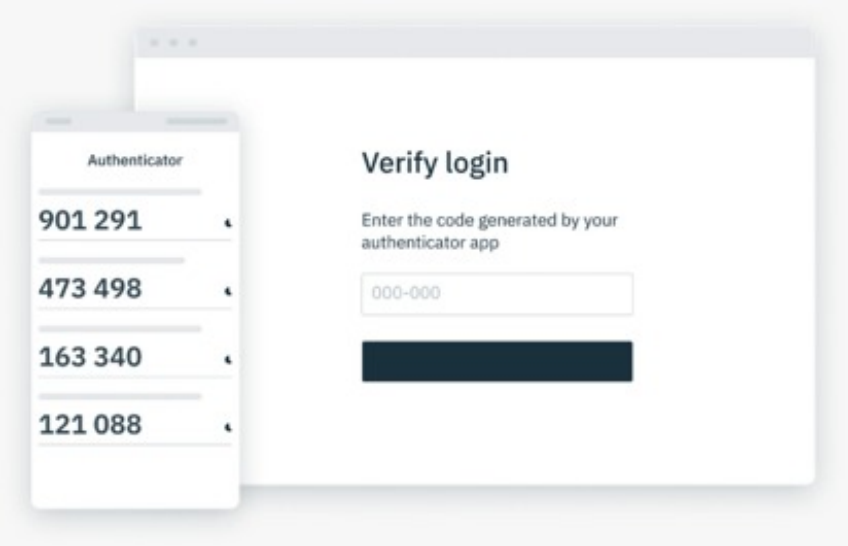


Figura 1: Geração de código temporário com tecnologia TOTP

Introduz-se a palavra-passe, o sistema valida as credenciais normais e gera um código usando um segredo partilhado e o intervalo de tempo atual. Após o utilizador introduzir o código, o sistema calcula o código esperado e compara os valores, validando deste modo o utilizador dentro da janela esperada e sem repetições.

Existe uma chave secreta conhecida pela aplicação autenticadora e pelo servidor, sendo também usados o tempo atual e um intervalo para calcular o espaço de tempo em que o código é válido. A chave e o valor temporal são passados então a uma função para produzir o código.

O TOTP reforça a segurança da autenticação, mas continua vulnerável a ataques de *phishing*. A sua eficácia depende da proteção do segredo partilhado e da correta sincronização dos relógios.

8.2 FIDO2 & WebAuthn

A tecnologia **FIDO2**, através do **WebAuthn**, permite autenticar utilizadores usando criptografia de chave pública, reduzindo a dependência de palavras-passe e reforçando a segurança do processo de autenticação.

O utilizador regista um autenticador, como um sensor biométrico integrado no dispositivo ou uma chave de segurança física. Durante este processo, é criado um par de chaves criptográficas associado ao serviço: uma chave privada, que permanece protegida no autenticador, e uma chave pública, que é armazenada pelo servidor.

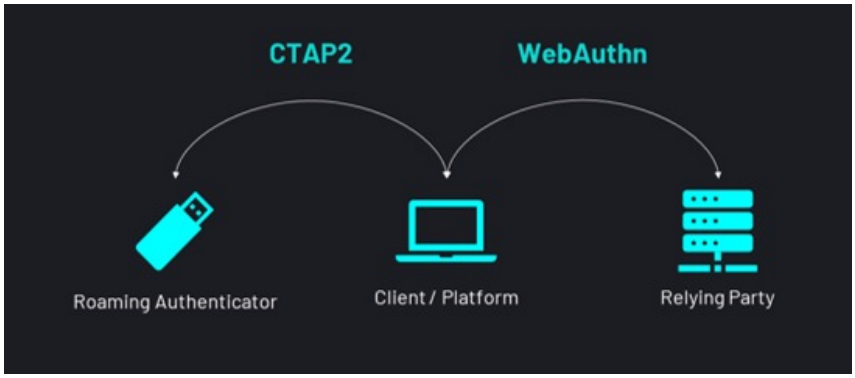


Figura 2: Arquitetura do FIDO2

O FIDO2 resulta da combinação de duas especificações complementares: o **WebAuthn**, que define a interface entre o serviço web e o *browser*, e o **CTAP2**, que define a comunicação entre o dispositivo do utilizador e o autenticador. Quando o autenticador é externo, como uma chave de segurança física, é o CTAP2 que permite ao *browser* ou ao sistema operativo comunicar com ele por USB, NFC ou *Bluetooth*, pedindo a criação de credenciais e a assinatura de desafios. No caso dos autenticadores integrados no dispositivo, esta comunicação é tratada pelo próprio sistema operativo. Assim, o serviço web interage apenas com o WebAuthn, e os detalhes da comunicação com o autenticador ficam a cargo do CTAP2, o que permite utilizar autenticadores de diferentes fabricantes de forma interoperável.

O servidor envia um desafio criptográfico único, que o autenticador assina com a chave privada após a autorização do utilizador. O servidor verifica a assinatura através da chave pública previamente registada, confirmando a autenticidade da resposta. Adicionalmente, o WebAuthn associa as credenciais ao domínio legítimo do serviço, dificultando a utilização das mesmas em páginas fraudulentas e reforçando a proteção contra ataques de *phishing*.

A sua eficácia depende da proteção das credenciais, da segurança do dispositivo e da implementação correta do protocolo.

8.3 Autenticação através de aplicações móveis e notificações push

As aplicações de autenticação móveis, como o Microsoft Authenticator ou o Google Authenticator, transformam o telemóvel do utilizador num fator de autenticação da categoria "algo que se possui", de forma a verificar que o utilizador é, de facto, o proprietário da conta que tenta autenticar-se. Depois de associada à conta, a aplicação passa a servir de segundo fator no início de sessão, através de dois mecanismos principais: a geração de códigos temporários e o envio de notificações *push* para aprovação do acesso. Ao contrário do SMS, estes mecanismos não dependem da rede móvel para a entrega da mensagem, o que reduz a exposição a certos ataques sobre o canal de comunicação. O estudo de Meyer et al. (2023) mostra que aplicações dedicadas, como o Microsoft Authenticator, oferecem mais proteção do que o SMS.

Nas notificações *push*, o serviço envia um pedido de aprovação para o dispositivo registado e o utilizador apenas decide se aceita ou não o início de sessão. Este método é rápido e não exige a introdução de códigos, o que melhora a experiência de utilização. No entanto, a simplicidade da aprovação é também a sua principal fragilidade. Num ataque de *MFA fatigue*, também conhecido como *push bombing*, o atacante que já possui a palavra-passe da vítima tenta repetidamente iniciar sessão, gerando uma sucessão de notificações no dispositivo do utilizador até que este aprove uma delas por engano ou por cansaço.

Um dos casos mais conhecidos em que o mecanismo de defesa eram as notificações *push* é o ataque à Uber, em setembro de 2022. Segundo o TechCrunch (2022), o atacante terá obtido acesso aos sistemas internos através da engenharia social de um prestador de serviços. De acordo com os relatos do incidente, o atacante bombardeou o prestador de serviços com notificações *push* e contactou-o depois através do WhatsApp, fazendo-se passar pelo apoio informático da Uber e pedindo-lhe que aprovasse uma das notificações. O prestador aprovou o pedido, o que deu ao atacante acesso à rede interna. Este caso mostra que a falha não esteve na tecnologia em si, mas na forma como a aprovação simples permite que o fator humano seja explorado.

Para reduzir este risco, a CISA (2022b) recomenda a utilização de *number matching*, em que o utilizador tem de introduzir na aplicação um número apresentado no ecrã de início de sessão. Desta forma, a aprovação deixa de ser um gesto automático e só quem está a iniciar a sessão consegue concluí-la. Contudo, a CISA (2022a) considera este método apenas uma solução intermédia e recomenda que as organizações migrem para MFA baseada em FIDO/WebAuthn.

Em síntese, as aplicações de autenticação oferecem um equilíbrio favorável entre segurança, custo e facilidade de utilização, sendo claramente preferíveis ao SMS e à autenticação por um único fator. Os códigos temporários são simples e funcionam sem

ligação à Internet, enquanto as notificações *push* proporcionam maior comodidade, desde que estejam acompanhadas de mecanismos como o *number matching*. Ambos os métodos dependem, contudo, da segurança do dispositivo móvel e exigem processos de recuperação de conta caso o utilizador perca o telemóvel. Em contextos de risco elevado, como contas de administração ou sistemas com informação sensível, justifica-se o recurso a métodos resistentes a *phishing*.

8.4 Códigos de utilização única por SMS

A autenticação através de códigos enviados por SMS é um método frequentemente utilizado na autenticação multifator, no qual o utilizador recebe, por mensagem de texto, um código temporário enviado pelo serviço a que pretende aceder. Após introduzir as suas credenciais habituais, como o nome de utilizador e a palavra-passe, o utilizador insere o código recebido no telemóvel para concluir o processo de autenticação. Com isto, acrescenta-se uma etapa de verificação associada ao acesso a um dispositivo que, em princípio, se encontra na posse do utilizador, dificultando o acesso não autorizado quando apenas a palavra-passe é comprometida.

Uma das principais vantagens deste método é a facilidade com que esta se usa e se implementa em serviços. Como não exige necessariamente a instalação de aplicações específicas ou a aquisição de dispositivos adicionais, pode ser uma solução acessível para um elevado número de utilizadores. Contudo, a utilização de SMS apresenta limitações de segurança que devem ser consideradas na escolha de um mecanismo de autenticação. Entre os riscos encontram-se a mudança de um cartão SIM para um dispositivo controlado por terceiros, a exploração de vulnerabilidades nas redes de telecomunicações e a possibilidade de um utilizador ser induzido a revelar o código recebido através de técnicas de engenharia social.

De acordo com o NIST, na publicação *Digital Identity Guidelines: Authentication and Authenticator Management* (SP 800-63B-4), a utilização da rede telefónica pública para a transmissão de códigos de autenticação é considerada um mecanismo de utilização restrita. O documento recomenda que sejam considerados indicadores de risco, como a substituição do cartão SIM, a alteração do número de telemóvel ou a portabilidade recente do número, antes de recorrer a este canal. O NIST salienta ainda a importância de obter métodos alternativos de autenticação, para quando o acesso à rede teleónica não está disponível. Além disso, os códigos introduzidos manualmente, como os recebidos por SMS, não são resistentes a ataques de phishing podendo ser obtidos por um atacante.

Assim, embora a autenticação por SMS possa representar uma melhoria face à utilização exclusiva de uma palavra-passe, não deve ser considerada a melhor opção para proteger contas ou recursos de elevada sensibilidade.

8.5 Smart Cards

Os Smart Cards são dispositivos físicos que armazenam credenciais eletrónicas utilizadas para verificar a identidade de um utilizador e controlar o acesso a sistemas ou instalações. No documento *Personal Identity Verification (PIV) of Federal Employees and Contractors* (FIPS 201-3), o NIST descreve que a utilização de cartões PIV serve para autenticação de funcionários e prestadores de serviços do governo federal dos Estados Unidos, tanto no acesso físico como no acesso a recursos informáticos.

De acordo com a secção 6.2.3.1 do FIPS 201-3, no mecanismo de autenticação PKI-AUTH, o sistema lê e valida o certificado de autenticação do cartão, solicita ao utilizador um PIN para o ativar e envia-lhe um desafio criptográfico. O cartão assina esse desafio com a chave privada armazenada, permitindo ao sistema verificar a resposta através da chave pública associada ao certificado. Se a validação for bem-sucedida, a identidade autenticada pode ser utilizada para determinar se o acesso deve ser autorizado.

Os cartões inteligentes podem suportar MFA quando são combinados fatores de autenticação distintos. Por exemplo, a apresentação do cartão corresponde a algo que o utilizador possui, enquanto a introdução de um PIN corresponde a algo que sabe. A exigência destes dois elementos dificulta a utilização indevida de um cartão perdido ou roubado, uma vez que a posse do cartão, por si só, não é suficiente para concluir o mecanismo de validação do utilizador. No entanto, nem todos os cartões inteligentes exigem dois fatores, pelo que a sua utilização nem sempre constitui automaticamente autenticação multifator.

Uma das principais vantagens dos cartões inteligentes é a possibilidade de recorrer a mecanismos criptográficos para verificar a autenticidade das credenciais, reduzindo a dependência de palavras-passe como único meio de autenticação. No mecanismo PKI-AUTH, o NIST destaca a elevada resistência à falsificação de credenciais, a resistência à utilização do cartão por pessoas que não sejam os seus titulares e a possibilidade de verificar se o certificado foi revogado. Além disso, os cartões PIV podem suportar diferentes mecanismos de autenticação permitindo adaptar o nível de garantia às necessidades de segurança do contexto.

Porém, a implementação deste tipo de solução pode exigir leitores compatíveis, sistemas de gestão de certificados e mecanismos para verificar o seu estado de validade ou revogação. Estes requisitos podem aumentar os custos de implementação e manutenção, especialmente em organizações com muitos utilizadores. Existe também o risco de perda ou roubo do cartão, pelo que é importante proteger a sua utilização através de mecanismos de ativação, como um PIN, e de procedimentos para bloquear ou revogar credenciais comprometidas. A escolha deste método deve, por isso, considerar o nível de segurança pretendido, a infraestrutura e os recursos disponível para a sua gestão.

Resumindo, os cartões inteligentes constituem uma boa solução para cenários que exigem uma autenticação robusta, sobretudo quando utilizam credenciais criptográficas e são combinados com um PIN ou outro fator independente. A sua adoção depende, contudo, do contexto de utilização e dos requisitos de segurança, devendo a organização avaliar se os benefícios justificam os custos e a complexidade de implementação.

8.6 Autenticação biométrica

A autenticação biométrica utiliza características físicas ou comportamentais de um indivíduo para verificar a sua identidade. De acordo com o *National Institute of Standards and Technology* (NIST), na publicação *Digital Identity Guidelines: Authentication and Authenticator Management* (SP 800-63B-4), estas características podem incluir impressões digitais, características faciais, padrões da íris, padrões de voz ou características comportamentais. Entre os exemplos mais comuns encontram-se o desbloqueio de um dispositivo através da impressão digital ou do reconhecimento facial.

O processo de autenticação começa com a recolha de uma amostra biométrica através de um sensor, como uma câmara ou um leitor de impressões digitais. Essa amostra é comparada com uma referência biométrica previamente registada, permitindo determinar se existe correspondência suficiente para aceitar a autenticação sendo esta comparação, segundo o NIST, probabilística, o que por esse motivo, os sistemas utilizam limiares de aceitação que procuram equilibrar a segurança e a facilidade de utilização.

De acordo com a secção *Use of Biometrics* do SP 800-63B-4, o NIST estabelece que a biometria deve ser utilizada como parte de um processo de autenticação multifator, em conjunto com um autenticador físico, correspondente a algo que o utilizador possui, por exemplo, a posse do dispositivo combinada com a característica biométrica por forma a desbloquear o acesso a um local/serviço.

A principal vantagem da autenticação biométrica é que esta proporciona uma experiência de utilização rápida e conveniente, reduzindo a necessidade de memorizar e introduzir palavras-passe ou códigos, pode também facilitar a utilização frequente de mecanismos de MFA, uma vez que o utilizador pode confirmar a sua identidade através de uma característica que lhe é própria.

Apesar das suas vantagens, a autenticação biométrica apresenta limitações relacionadas com a precisão, a privacidade e a resistência a ataques. Situações como esta podem ocorrer, por exemplo, devido a alterações na iluminação durante o reconhecimento facial, à presença de humidade ou sujidade nos dedos ou a lesões que afetem a leitura das impressões digitais. Outra limitação relevante diz respeito à proteção dos dados biométricos. Ao contrário de uma palavra-passe, uma característica física não pode ser facilmente alterada caso seja comprometida. Por esse motivo, o NIST determina que os dados biométricos

sejam tratados e protegidos como informação pessoal sensível.

Por fim, a autenticação biométrica pode contribuir para uma experiência de autenticação mais simples e para o reforço da segurança, desde que seja integrada num mecanismo de MFA adequado. A sua implementação deve ter em conta a precisão do sistema, a proteção dos dados pessoais, a resistência a ataques e a disponibilidade de métodos alternativos. Desta forma, a escolha da biometria deve considerar tanto o nível de segurança pretendido como as necessidades e limitações dos utilizadores.

8.7 Comparação entre as tecnologias analisadas

A comparação entre as várias tecnologias apresentadas anteriormente apresentam-se na Tabela 1 onde se demonstra cada tecnologia, o seu funcionamento, vantagens e as suas limitações.

Tecnologia	**Funcionamento**	**Vantagens**	**Limitações**
TOTP	Gera códigos temporários através de uma aplicação e de uma chave partilhada.	Funciona sem ligação à Internet no momento da geração do código.	Os códigos podem ser roubados através de phishing.
FIDO2 / WebAuthn	Utiliza chaves criptográficas para autenticar o utilizador.	Elevada resistência a phishing e não exige a introdução de códigos.	A compatibilidade e a configuração podem variar consoante os dispositivos e serviços.
Aplicações móveis e notificações push	Envia uma notificação para um dispositivo registado, solicitando a aprovação do acesso.	Utilização simples e rápida.	Pode ser vulnerável a aprovações indevidas ou a ataques de fadiga de MFA.
SMS	Envia um código temporário por mensagem de texto.	Fácil de utilizar e amplamente acessível.	Vulnerável a troca de SIM, engenharia social e phishing.
Smart Cards	Utiliza um cartão físico com credenciais, podendo exigir um PIN.	Permite autenticação criptográfica robusta e controlo de acesso.	Pode exigir leitores, infraestrutura específica e gestão de certificados.
Biometria	Compara características físicas, como a impressão digital ou o rosto.	Rápida e conveniente para o utilizador.	Pode apresentar erros de reconhecimento e riscos de privacidade.

Tabela 1: Comparação entre tecnologias de autenticação multifator.

9 Conclusões

O presente trabalho analisou as diferenças entre a Autenticação Simples (SFA) e a Autenticação Multifator (MFA), considerando os seus fundamentos técnicos, vantagens, limitações e adequação a diferentes perfis de utilizador e contextos de risco.

A SFA, embora simples e de baixo custo, apresenta vulnerabilidades significativas, sobretudo quando baseada exclusivamente em palavras-passe. A MFA, ao exigir fatores de categorias distintas, reduz drasticamente o risco de comprometimento, segundo Meyer et al. (2023), em 99,22% na população total e em 98,56% mesmo quando as credenciais já foram divulgadas. Contudo, a sua eficácia depende do método escolhido: SMS e notificações push continuam vulneráveis a ataques como AiTM e push bombing, enquanto FIDO2/WebAuthn oferece resistência superior a phishing.

A análise por perfil de utilizador demonstrou que a necessidade de MFA varia consoante o risco e as características do utilizador. Para o utilizador comum, é fortemente recomendada em contas críticas. Para o utilizador idoso, deve ser adaptada às suas capacidades. Para utilizadores com acesso a informação sensível ou privilégios elevados, é essencial e deve ser complementada com gestão de sessões e monitorização contínua.

Conclui-se que não existe uma solução única: a escolha entre SFA e MFA deve ser informada pelo nível de risco, pela sensibilidade da informação e pelo perfil do utilizador. A autenticação baseada no risco, que ajusta o nível de verificação em tempo real, surge como a abordagem mais promissora para conciliar segurança e usabilidade.

9.1 Trabalhos Futuros

De forma a concluirmos qual a melhor abordagem para cada perfil de utilizador, como continuação do trabalho até agora desenvolvido, iremos aprofundar e pôr em prática, os seguintes aspetos:

- **Matriz de decisão por perfil e risco:** Construir um modelo que, dado um perfil de utilizador e um contexto, recomenda SFA, MFA ou MFA obrigatório.
- **Protótipo simples de autenticação adaptativa:** Login adaptativo, que só pede o segundo fator quando deteta sinais de risco (novo dispositivo, horário invulgar, várias tentativas falhadas, etc.).
- **Análise de casos reais:** Comparar o que serviços concretos exigem (banca online, e-mail, plataformas de e-learning, redes sociais, etc.) e justificar se a escolha é proporcionada ao risco.
- **Questionário de usabilidade:** Inquérito a pessoas de perfis diferentes sobre a perceção de segurança e incómodo de cada método.

10 Referências

- NIST - *Glossário de Single-Factor*
  Disponível em: https://csrc.nist.gov/glossary/term/single_factor
- TechTarget - *Single-factor authentication (SFA)*
  Disponível em: https://www.techtarget.com/cybersecurity/definition/single-factor-authentication-SFA
- Caixa Geral de Depósitos (CGD) - *Dados biométricos*
  Disponível em: https://www.cgd.pt/Site/Saldo-Positivo/formacao-e-tecnologia/Pages/dados-biometricos.aspx
- TechTerms - *Hard Token*
  Disponível em: https://techterms.com/pt/definition/hard_token
- Otta, S. P., Panda, S., Gupta, M. e Hota, C. - *A Systematic Survey of Multi-Factor Authentication for Cloud Infrastructure.* Future Internet, vol. 15, n.º 4, artigo 146, 2023.
  Disponível em: https://www.mdpi.com/1999-5903/15/4/146
- CISA - *Turn on Multifactor Authentication (MFA)*
  Disponível em: https://www.cisa.gov/secure-our-world/turn-mfa
- U.S. Senate Committee on Homeland Security and Governmental Affairs - *Portman Presses President and CEO of Colonial Pipeline on Gaps in Cybersecurity Practices*
  Disponível em: https://www.hsgac.senate.gov/media/reps/portman-presses-president-and-ceo-of-colonial-pipeline-on-gaps-in-cybersecurity-practices/
- Sanchari Das , Joshua Streiff , Lesa L Huber , L Jean Camp - *Why Don't Elders Adopt Two-Factor Authentication? Because They Are Excluded by Design*
  Disponível em: https://academic.oup.com/innovateage/article/3/Supplement_1/S325/5617506
- C. S. Weir, G. Douglas, T. Richardson e M. Jack (2010) - *Usable security: User preferences for authentication methods in eBanking and the effects of experience*
  Disponível em: https://academic.oup.com/iwc/article-abstract/22/3/153/693231
- E. De Cristofaro, H. Du, J. Freudiger e G. Norcie (2014) - *A Comparative Usability Study of Two-Factor Authentication*
  Disponível em: https://www.ndss-symposium.org/wp-content/uploads/2017/09/01_5-paper.pdf

- Allafi e Darem (2025) - *Usability and security in online authentication systems*
  Disponível em: https://www.science-gate.com/IJAAS/Articles/2025/2025-12-06/1021833ijaas202506001.pdf
- Stephan Wiefling, Markus Dürmuth e Luigi Lo Iacono (2020) - *More Than Just Good Passwords? A Study on Usability and Security Perceptions of Risk-based Authentication*
  Disponível em: https://arxiv.org/pdf/2010.00339
- Kurt Thomas e Angelika Moscicki (2019) - *How effective is basic account hygiene at preventing hijacking*
  Disponível em: https://security.googleblog.com/2019/05/new-research-how-effective-is-basic.html?m=1
- L. A. Meyer, S. Romero, G. Bertoli, T. Burt, A. Weinert e J. M. Lavista Ferres (2023) - *How effective is multifactor authentication at deterring cyberattacks?*
  Disponível em: https://www.microsoft.com/research/publication/how-effective-is-multifactor-authentication-at-deterring-cyberattacks/
- K. Thomas e A. Moscicki (2019) - *New research: How effective is basic account hygiene at preventing hijacking*
  Disponível em: https://security.googleblog.com/2019/05/new-research-how-effective-is-basic.html
- CISA (2022a) - *Implementing Phishing-Resistant MFA*
  Disponível em: https://www.cisa.gov/sites/default/files/publications/fact-sheet-implementing-phishing-resistant-mfa-508c.pdf
- CISA (2022b) - *Implementing Number Matching in MFA Applications*
  Disponível em: https://www.cisa.gov/sites/default/files/publications/fact-sheet-implement-number-matching-in-mfa-applications-508c.pdf
- NIST - *Digital Identity Guidelines: Authentication and Authenticator Management (SP 800-63B-4)*
  Disponível em: https://csrc.nist.gov/pubs/sp/800/63/b/4/final
- NIST - *Personal Identity Verification (PIV) of Federal Employees and Contractors (FIPS 201-3)*
  Disponível em: https://csrc.nist.gov/pubs/fips/201-3/final
- Cloudflare - *How Cloudflare mitigated yet another Okta compromise*
  Disponível em: https://blog.cloudflare.com/how-cloudflare-mitigated-yet-another-okta-compromise/
- L. A. Meyer, S. Romero, G. Bertoli, T. Burt, A. Weinert e J. M. Lavista Ferres

(2023) - *How effective is multifactor authentication at deterring cyberattacks?* https://www.microsoft.com/research/publication/how-effective-is-multifactor-authentication-at-deterring-cyberattacks/

- TechCrunch (2022) - *How to fix another Uber breach* https://techcrunch.com/2022/09/19/how-to-fix-another-uber-breach/
- Stytch - *Introducing TOTP Authentication* Disponível em: https://stytch.com/blog/introducing-totp-authentication/
- Bhanushali, Sameer - *The Passwordless Future: FIDO2 and WebAuthn* Disponível em: https://sameerbhanushali.substack.com/p/the-passwordless-future-fido2-and